Computer Security — Midterm Practice Exam (Teacher's Style)

MAIN TEST · Built from the teacher's *Midterm Guidance* · Weeks 1–6 · 70 questions · Answers and guidance model answers at the end

Name: _____	**Student ID:** _____	**Score:** _____ / 70

About this exam. The teacher's guidance lists 35 questions (5–7 per week) and one sample item: a short scenario, then four options that each give a **classification plus a reason or control** (for example "Integrity: allow only authorized staff to edit grade records"). Every question below copies that style, and there are **two questions for each guidance point**, so the whole guidance is covered. Watch for options with the **right label but the wrong reason**: that is the trap in the teacher's sample.

Instruction: Choose one best answer.

Week 1 — Introduction to Computer Security

1. Just before a deadline, the LMS is flooded with traffic and students cannot submit. Which option identifies the main CIA goal affected and a suitable control?

A. Confidentiality: require MFA on every student account.
B. Integrity: keep version history of submitted files.
C. Availability: use redundancy and monitoring so the service stays usable.
D. Integrity: hash each submitted file.

2. A private research document is shared with a public link, and outsiders read it. Which option identifies the main CIA goal affected and a suitable control?

A. Confidentiality: restrict sharing permissions to the intended people.
B. Integrity: keep version history of the document.
C. Availability: copy the document to a backup server.
D. Availability: add a second Internet connection.

3. Which pairing of a CIA goal and a control is correct?

A. Availability: a privacy screen on the monitor.
B. Confidentiality: a redundant power supply.
C. Integrity: a second Internet link.
D. Integrity: checks for changes, such as hashes and version history.

4. A department wants its files to remain usable if the main storage fails. Which option fits best?

A. Confidentiality: stronger sharing permissions.
B. Availability: tested backups and redundant storage.
C. Integrity: a screen lock on every computer.
D. Confidentiality: encryption of every file.

5. A software bug in an update corrupts the course timetable. Nobody attacked the system. Which statement is best?

A. It is not a security problem, because there was no attacker.
B. It is a security problem: the data is no longer correct (integrity) and may be unusable (availability), even though it was an accident.
C. It is only a confidentiality problem, because staff could see the timetable.
D. It is a security problem only if the data was stolen.

6. Which answer best describes what computer security protects?

A. Only computer hardware.

B. Only passwords.

C. Information, devices and services, and people's time, trust, privacy and safety.

D. Only the Internet connection.

7. A university has a strong password system, but some staff read their passwords to callers who claim to be IT. What does this show?

A. Technology alone is not enough: people and process (training, a "never share passwords" rule, reporting) are also needed.

B. The password system should be removed.

C. Only more technology can fix it.

D. Process is unnecessary if the technology is strong.

8. Why does the course recommend defense in depth?

A. One perfect control is enough, and layers only add cost.

B. Layers make users careless.

C. Layers replace the need for user training.

D. Any single control can fail, so another layer can catch what it misses.

9. A student notices that a university server is reachable from the dorm network and wants to scan it "to help". What should the student do?

A. Scan quietly and report the findings later.

B. Scan it, because a reachable server is allowed to be tested.

C. Not scan it: testing needs permission from the owner with a clear scope, time, method and purpose, so ask first.

D. Scan it and post the results to warn other students.

10. During an approved lab exercise, you notice another machine that is not on the instructor's target list. What should you do?

A. Stop and ask the instructor, because the machine is outside the agreed scope.

B. Scan it, because you are already authorized for the lab.

C. Scan it after class when nobody is watching.

D. Ask a classmate to scan it instead.

Week 2 — Assets, Threats and Risk

11. Classify the university's online exam platform and explain its value.

A. Information: it is valuable because it was expensive to buy.

B. Service: it is valuable because students rely on its function during exams, and it depends on servers, the network and accounts.

C. Device: it is a physical tool on a desk.

D. People: it holds staff knowledge.

12. Two identical laptops: one shows a public notice in a lobby, the other supports urgent patient care. Which statement is correct?

A. They have the same value because they have the same price.

B. The lobby laptop is more valuable because more people see it.

C. Value depends only on the purchase price.

D. The patient-care laptop has higher value because of what it does and what depends on it.

13. *Scenario for 13–14:* hospital servers run old software with a known, unfixed flaw. A criminal group uses the flaw to install ransomware. Which item is the **vulnerability**?

A. The known, unfixed flaw in the old software.
B. The criminal group.
C. Using the flaw to install ransomware.
D. Applying a verified patch.

14. In the same scenario, "using the flaw to install ransomware" is the:

A. Threat: a possible cause of harm.
B. Vulnerability: the weakness.
C. Exploit: a way of using the weakness.
D. Control: a protective measure.

15. A flood damages a data center and the servers stop. Which option classifies the threat correctly?

A. Malicious: someone deliberately caused harm.
B. Accidental: a staff member made a mistake.
C. It is not a threat, because no person was involved.
D. Physical: physical damage harmed devices and made services unavailable.

16. An administrator runs a delete command on the wrong database and data is lost (like GitLab 2017). Which option is correct?

A. Malicious: the administrator meant to cause harm.
B. Accidental: unintended harm that caused an integrity loss.
C. Physical: hardware was damaged.
D. Not a threat, because a staff member did it.

17. Likelihood = 2 (possible) and impact = 2 (serious). Using the class risk matrix:

A. 2 × 2 = 4, Medium.
B. 2 × 2 = 4, High.
C. 2 + 2 = 4, Low.
D. 2 × 3 = 6, High.

18. Likelihood = 3 (likely) and impact = 2 (serious). Using the class risk matrix:

A. 3 + 2 = 5, Medium.
B. 3 × 2 = 6, Medium.
C. 3 × 2 = 6, High.
D. 3 × 3 = 9, High.

19. Which statement about a verified patch is correct?

A. It mainly reduces impact, because fewer files are lost.
B. It mainly reduces likelihood, because it closes that exploitation route.
C. It reduces both to zero, so no risk remains.
D. It only reduces cost.

20. A successful, tested restore exists for a system that ransomware could hit. Which statement is correct?

A. The ransomware event can no longer happen.
B. Likelihood becomes zero.
C. Impact increases, because restoring takes time.
D. It mainly reduces impact: less is lost and service returns faster, although the event can still happen.

Week 3 — Social Engineering and Phishing

21. "This is the campus finance office. Your scholarship will be cancelled in 30 minutes unless you confirm your bank password here." Which option identifies the parts correctly?

A. Invented story: scholarship cancellation; requested action: give the bank password; levers: authority and urgency (with fear).

B. Invented story: give the password; requested action: the scholarship; lever: reward.

C. Invented story: the finance office; requested action: wait 30 minutes; lever: curiosity.

D. It is not social engineering, because it mentions a real office.

22. "Someone tagged you in an embarrassing video. Watch it here." Which lever is mainly used?

A. Authority: the message claims to be official.

B. Reward: the message offers a prize.

C. Curiosity: it makes you want to see the content.

D. Familiarity: it claims to be a friend with a new number.

23. A caller says they are from your bank, uses your name and a recent purchase, and asks for the code you just received. Which labels fit best?

A. Smishing only: it arrived as a text.

B. Vishing + spear phishing + impersonation: voice channel, personalized details, claimed identity.

C. Baiting: it offers something attractive.

D. Broad phishing only: it is a generic message.

24. Why can one message fit more than one label?

A. The labels are synonyms for the same thing.

B. It cannot; each message has exactly one label.

C. Labels depend on the attacker's country.

D. Each label describes a different feature: channel, targeting or claimed identity.

25. A video call shows your manager's face and voice and asks for an urgent payment. What should you do?

A. Pay: a familiar face proves the request is genuine.

B. Pay if the voice also matches.

C. Verify through an independent route and the normal approval process: recognition is not authorization, and deepfakes can imitate faces and voices.

D. Refuse every video call for the rest of the year.

26. A USB stick labelled "Salary list 2026" is lying in the car park. Which option is correct?

A. Baiting: do not plug it in; hand it to IT.

B. Tailgating: plug it into a computer that is not yours.

C. Vishing: call the number written on it.

D. It is not a risk, because it was found on campus.

27. Which address really belongs to `portal.kyungsung.example`?

A. `https://portal.kyungsung.example.login-check.test/`

B. `https://kyungsung-example-portal.com/`

C. `https://portal-kyungsung.example.net/`

D. `https://portal.kyungsung.example/login`

28. Which message shows the strongest warning signs?

A. The weekly newsletter you subscribed to.

B. An unexpected message with a deadline that asks for your login code or for you to install a remote-access app.

C. A timetable update you expected on the official portal.

D. A library due-date reminder.

29. A message has the correct university logo, fluent writing and an HTTPS link. What does this prove?

A. Nothing certain: logos, names and fluent text can be copied, and HTTPS also protects connections to fake sites.

B. It is genuine, because it uses HTTPS.

C. It is genuine, because the logo is correct.

D. It is genuine, because the writing is fluent.

30. Which is the strongest evidence that a sensitive request is genuine?

A. The display name of the sender.

B. A professional layout.

C. Confirming the exact request through a known official contact route that you obtained separately.

D. The padlock in the browser.

31. You approved a login prompt that you did not start. What is the best response?

A. Wait and see if anything happens.

B. Approve it again to cancel it.

C. Delete the authenticator app.

D. Report it to IT through the official route, change the password and end active sessions.

32. In Korea, you already sent money to a voice-phishing caller. What should you do first?

A. Contact 118 (KISA) only.

B. Call 112 and your bank's official contact immediately and request payment suspension.

C. Reply to the caller and ask for a refund.

D. Post a warning on social media.

Week 4 — Identity, Authentication and Access Control

33. Joon signs in with the correct password and MFA, then tries to open the grade-editing page and is refused. Which check refused him?

A. Identification: he did not claim an account.

B. Authentication: his proof did not match.

C. Authorization: his student role does not permit editing grades.

D. The session: it expired.

34. An attacker reuses a stolen session token and reaches the account without knowing the password. What was abused?

A. The session: it recognizes later requests after sign-in.

B. The account record: it stores role and status.

C. The permission check: it decides access to a resource.

D. The password hash.

35. An attacker tries username–password pairs leaked from a forum on the university portal. Which option is correct?

A. Password guessing: it tries common passwords such as 123456.
B. Credential stuffing: it reuses leaked pairs, so it works only where a password was reused.
C. Offline guessing: it tests a copied hash.
D. Phishing: it tricks the user into typing the password.

36. Where do login attempt limits help?

A. Against offline guessing of a copied hash.
B. Equally against online and offline guessing.
C. Against neither.
D. Against online guessing, where every guess goes to the login service.

37. Why use a password manager?

A. It lets you safely reuse one password everywhere.
B. It removes the need for any password.
C. It makes a long, unique, random password for every service practical, so one leak does not spread.
D. It stores passwords in a plain notes file.

38. A student uses `Kyungsung2026!` on every site. What is the best advice?

A. Use long, random, unique passwords from a password manager: this one follows a predictable pattern, and reuse spreads one breach to every site.
B. Add one more `!` at the end.
C. Change the year every January.
D. Keep it, but turn on dark mode.

39. Which sign-in combination is valid MFA?

A. Password + PIN.
B. Password + security question.
C. Two different passwords.
D. Password + fingerprint.

40. Why is "password + security question" not MFA?

A. Security questions are too long.
B. Both are something you know: the same factor type.
C. Security questions are biometric.
D. It is MFA, because there are two steps.

41. An app shows the verification-code page after the password, but if you type the account page's address directly, it opens. What is wrong?

A. Password storage failed: the hash was too fast.
B. The user made an error.
C. The app does not check MFA completion on the protected page; every protected route must refuse access until MFA is finished.
D. The network was down.

42. Your phone shows an unexpected login approval request. What should you do?

A. Deny it, check the account through the official service, and report it.
B. Approve it to see what happens.
C. Leave it pending.
D. Approve it, then change the password tomorrow.

43. A TA assigned to section A edits a grade in section B. Which failure is this?

A. Vertical: the TA used a more privileged action.
B. Horizontal: the same role reached a resource outside its assigned scope.
C. Authentication: the TA's password was wrong.
D. No failure: TAs may edit any grade.

Access log for question 44:

Time	Account	Event	Decision
09:10	student.lee	Read own grade	Allow
09:11	student.lee	Edit course grades	Allow
09:12	student.lee	Read own timetable	Allow

44. Read the access log above. Which row violates the policy for a student account?

A. 09:10: horizontal failure.
B. 09:12: horizontal failure.
C. None of the rows.
D. 09:11: a student edited course grades, a vertical failure.

Week 5 — Malware and Endpoint Security

45. Malware spreads to every unpatched computer in a lab without anyone opening a file. Which option is correct?

A. Worm: it spreads by itself across the network to reachable, unpatched systems.
B. Virus: it needs a user to run an infected file.
C. Trojan: it is disguised as a useful program.
D. Spyware: it collects information.

46. How do a virus and a worm spread differently?

A. A virus spreads by itself; a worm needs a user.
B. They spread in exactly the same way.
C. A virus needs an infected file or program to be run or shared; a worm spreads itself through reachable, unpatched systems.
D. Worms spread only through USB sticks.

47. A laptop is slower than usual, but there are no scan detections, unknown processes or network evidence. What is the best conclusion?

A. It is definitely ransomware.
B. Infection is not proven: symptoms alone do not prove malware, so collect evidence.
C. It is definitely a worm.
D. You must pay to fix it.

48. A fake update installs a hidden keylogger and later downloads ransomware. Which option is correct?

A. Only a Trojan.
B. Only ransomware, because the files are encrypted at the end.
C. Only a virus.
D. Trojan + spyware + ransomware: malware can combine types and stay hidden before its impact.

49. A vendor's legitimate software update was compromised and installed malware at many customers. Which infection path is this?

A. Removable media.
B. Weak configuration.
C. Supply chain.
D. Malicious message.

50. Infection began when an employee opened `salary.docx` from a known colleague whose account had been hacked. Which option is correct?

A. Malicious message / attachment: a known contact can be compromised, so unexpected content still needs verifying.
B. Supply chain: the vendor was compromised.
C. Removable media: a USB was used.
D. Unpatched service: a worm spread by itself.

51. Malware disabled the security tools because the user always worked as an administrator. Which control fits best?

A. A bigger monitor.
B. Standard user accounts for daily work (least privilege).
C. Turning off updates.
D. Allowing auto-run for USB devices.

52. Why is antivirus alone not enough?

A. Antivirus is illegal on university computers.
B. Antivirus always makes computers too slow.
C. No tool detects every threat; protection also depends on updates, configuration, privilege, backups and users.
D. Antivirus only works offline.

53. Ransomware also encrypted the backup drive, which was always connected. What is the lesson?

A. Backups are useless.
B. Paying the ransom is the only option.
C. Use more connected drives.
D. Backups must be protected, separated and tested.

54. Files were restored after an infection, but the same malware returned a week later. Why?

A. Recovery restored the data but did not fix the original weakness; the system must be returned to a trusted state.
B. The backup was too new.
C. The antivirus was too strong.
D. Restoring always causes reinfection.

55. After a fake update, a library computer shows pop-ups and opens unknown pages. What is the first action?

A. Continue online banking, but quickly.
B. Delete system files yourself to remove it.
C. Ignore it.
D. Stop sensitive work, report to IT and follow their guidance.

56. Why should you not keep experimenting on a device you suspect is infected?

A. It is boring.
B. It can cause more harm and destroy evidence that support staff need.
C. Antivirus forbids it.
D. It makes removal faster.

Week 6 — Networking Fundamentals for Security

57. A university links its two campuses in different cities. Which option is correct?

A. WAN: it links networks over larger distances.
B. LAN: it covers a limited local area.
C. Access point: it lets wireless devices join.
D. Switch: it forwards frames inside a LAN.

58. The Internet connection fails. Can you still print to the lab printer on the same switch?

A. No: printing needs the Internet.
B. Only if you use HTTPS.
C. Yes: the print job stays local (laptop → access point → switch → printer).
D. Only after DNS works again.

59. Which device forwards IP packets from the campus LAN to other networks and acts as the default gateway?

A. Switch.
B. Router.
C. Access point.
D. Printer.

60. Which path from a laptop to the cloud LMS is correct?

A. Laptop → router → switch → access point → server.
B. Laptop → server, directly.
C. Laptop → printer → switch → server.
D. Laptop → access point → switch → router/firewall → Internet routers → server.

61. Which statement is correct?

A. 192.168.10.24 is a private address; NAT lets it share the public address 203.0.113.5; port 443 is HTTPS and 22 is SSH.
B. 192.168.10.24 is a public address that is globally routable.
C. NAT translates domain names into IP addresses.
D. Port 22 is HTTPS and 443 is SSH.

62. What does DNS do?

A. Assigns port numbers.
B. Encrypts web pages.
C. Lets private addresses share one public address.
D. Finds the IP address that matches a domain name.

63. In `https://lms.example.com/course/6`, which option is correct?

A. Scheme `lms`, domain `https`, path `example.com`.
B. Scheme `course`, domain `6`, path `lms`.
C. Scheme `https`, domain `lms.example.com`, path `/course/6`.
D. Scheme `https`, domain `/course/6`, path `lms.example.com`.

64. Which pairing of protocol and role is correct?

A. TLS: delivers packets between networks.

B. TCP: reliable, ordered delivery; TLS: encryption and certificate checks.

C. HTTP: encryption of the connection.

D. IP: defines web requests and responses.

65. A phishing page shows a padlock. Which statement is correct?

A. It must be genuine, because HTTPS is used.

B. HTTPS is broken.

C. HTTPS only protects data in transit to whatever site you connected to; phishing sites can also have certificates.

D. The padlock means the government approved the site.

66. Spyware is running on your laptop and you log in to your bank over HTTPS. Which statement is correct?

A. The spyware can still read data on your device: HTTPS does not protect an infected endpoint.

B. You are safe, because HTTPS encrypts everything.

C. HTTPS removes the spyware.

D. Only the Wi-Fi password matters.

67. An attacker sets up a hotspot with the same name as a café's real Wi-Fi. Which option names the risk and where it occurs?

A. DNS spoofing, at the server.

B. Exposed service, at the boundary.

C. On-path attacker, at the server.

D. Evil twin, at network access (the access point).

68. A public file server accepts SSH (port 22) from the whole Internet, although only IT needs it. Which option fits?

A. Evil twin: use verified Wi-Fi.

B. Unnecessarily exposed service at the boundary: firewall rules should allow only an approved admin path.

C. DNS spoofing: check the certificate.

D. Phishing: train users.

69. Guest Wi-Fi devices can reach the staff payroll server. Which control fits best?

A. Segmentation with firewall rules: guest → Internet allow, guest → payroll deny.

B. Valid HTTPS on the payroll server only.

C. A longer Wi-Fi name.

D. Antivirus on the payroll server only.

70. At a café, your browser shows a certificate warning for the campus portal. What should you do?

A. Click "continue anyway", because you know the portal.

B. Turn off certificate warnings.

C. Stop and do not enter credentials; check later from a trusted network or device and report it, because the cause could be the device, the network or the site.

D. Type your password quickly before the connection closes.

Answer Key

Q	Ans	Guidance	Why
1	C	W1.1	Service cannot be used → availability; redundancy/monitoring keep it running.
2	A	W1.1	Seen by unauthorized people → confidentiality; fix the sharing permissions.
3	D	W1.2	Integrity controls detect or undo changes. The others pair a goal with another goal's control.
4	B	W1.2	Usable when needed = availability: backups, redundancy.
5	B	W1.3	Accidents and technical failures also break integrity and availability.
6	C	W1.3	Information, devices + services, people + reputation.
7	A	W1.4	People, process and technology must work together.
8	D	W1.4	Any single control can fail.
9	C	W1.5	Reachable ≠ allowed; authorized testing needs owner, scope, time, method, purpose.
10	A	W1.5	When scope is unclear: stop and ask.
11	B	W2.1	Services are functions people rely on; value comes from what it does; note its dependencies.
12	D	W2.1	Same price, different value.
13	A	W2.2	Vulnerability = the flaw.
14	C	W2.2	Exploit = the use of the flaw. The group is the threat.
15	D	W2.3	Physical threat (like the Kakao 2022 fire).
16	B	W2.3	Unintended harm = accidental threat.
17	A	W2.4	4 falls in the Medium band (3–4).
18	C	W2.4	6 falls in the High band (6–9). Always multiply.
19	B	W2.5	A patch closes the route → likelihood.
20	D	W2.5	A restore limits loss → impact.
21	A	W3.1	Story vs action; "finance office" = authority, "30 minutes" = urgency, "cancelled" = fear.
22	C	W3.1	Curiosity.
23	B	W3.2	Voice + personalized + claimed identity.
24	D	W3.2	Each label describes a different feature.
25	C	W3.3	Recognition is not authorization (Hong Kong deepfake).
26	A	W3.3	Baiting: an attractive item invites a risky action.
27	D	W3.4	Read the hostname from the right; A belongs to `login-check.test`.
28	B	W3.4	Unexpected + pressure + sensitive action (code, remote access).
29	A	W3.5	Appearance is limited evidence; HTTPS protects deceptive sites too.
30	C	W3.5	Verified contact through an independent route.
31	D	W3.6	Approved a login → report, reset credentials, end sessions through a trusted route.
32	B	W3.6	Money sent → 112 + bank, payment suspension.
33	C	W4.1	Authentication passed; permission for the action failed.
34	A	W4.1	A stolen session is reused for later requests.
35	B	W4.2	Stuffing reuses leaked pairs.

Q	Ans	Guidance	Why
36	D	W4.2	Offline guesses never reach the login service.
37	C	W4.3	Uniqueness becomes practical.
38	A	W4.3	Predictable pattern (word + year + symbol) and reuse.
39	D	W4.4	Know + are. A, B, C are know + know.
40	B	W4.4	Two screens can still ask for the same kind of proof.
41	C	W4.5	A verification screen alone does not enforce the rule.
42	A	W4.5	An unexpected prompt is denied and investigated, never approved.
43	B	W4.6	Same role level, resource outside scope → horizontal.
44	D	W4.6	A student role edits nothing; editing course grades is a more privileged action → vertical.
45	A	W5.1	No user action → worm.
46	C	W5.1	Virus needs execution/sharing; worm self-propagates.
47	B	W5.2	Symptoms alone do not prove infection.
48	D	W5.2	Types combine; spyware hides quietly.
49	C	W5.3	Compromised legitimate vendor/update.
50	A	W5.3	Malicious attachment from a compromised known contact.
51	B	W5.4	Least privilege limits what malware can change.
52	C	W5.4	Defense in depth.
53	D	W5.5	A connected backup can be encrypted too.
54	A	W5.5	Restoring files alone may restore the weakness.
55	D	W5.6	Stop, report, follow guidance.
56	B	W5.6	Avoid unnecessary changes; staff may need evidence.
57	A	W6.1	WAN = larger distances.
58	C	W6.1	Local traffic does not need the Internet.
59	B	W6.2	Router = default gateway between networks.
60	D	W6.2	The week 6 path.
61	A	W6.3	Private + NAT + well-known ports.
62	D	W6.3	DNS: name → address.
63	C	W6.4	Scheme / domain / path.
64	B	W6.4	IP = packets between networks, TCP = reliable order, HTTP = requests, TLS = protection.
65	C	W6.5	HTTPS proves an encrypted connection, not honesty.
66	A	W6.5	Endpoint security still matters.
67	D	W6.6	Evil twin, at access.
68	B	W6.6	Too much exposure, at the boundary.
69	A	W6.7	Segmentation limits unnecessary paths.
70	C	W6.7	Stop at certificate warnings; name the location first.

Model Answers to the 35 Guidance Questions

Short answers you can say or write in the exam. Each one matches a numbered point on the teacher's guidance sheet.

Week 1

1. CIA. Confidentiality = only authorized people can see it. **Integrity** = it is correct, complete and trustworthy. **Availability** = authorized people can use it when needed. Scenario test: *seen by the wrong person → C; changed or corrupted → I; cannot be used → A.*

2. Controls per goal. C: access permissions, sharing settings, unique passwords, MFA, screen lock. I: access control, validation, checks for changes (hashes, logs, version history), backups to restore correct data. A: backups, redundancy, maintenance, monitoring, recovery plans.

3. What is protected. Information (grades, messages, identity and payment data), devices and services (phones, laptops, LMS, e-mail, Wi-Fi), and people and reputation (time, trust, privacy, safety). Accidents and failures (wrong edit, bug, power or hardware failure, bad update) still make data untrustworthy or unusable, so they are security problems even with no attacker.

4. People, process, technology; defense in depth. People make choices, process says what to do, technology blocks, detects, records and recovers. Technology fails if a person gives a password away. Defense in depth = several layers (aware users, strong authentication, device protection, network controls, monitoring, backups) because any single control can fail.

5. Authorized testing. A clear **owner, scope, time, method and purpose**, and private handling of results. Reachable does not mean allowed. If permission or scope is unclear: **stop and ask**.

Week 2

1. Assets. Information (records, grades, passwords), devices (laptops, phones, hospital computers), people (staff, students, patients), services (online exams, messaging, payments). Value comes from what the asset does, not its price; dependency = what it needs to work (Facebook 2021: one network change, services failed together).

2. Terms. Threat = possible cause of harm; vulnerability = weakness; exploit = a way to use the weakness; control = protective measure; risk = possible future harm judged by likelihood and impact; incident = something that has already happened. Equifax: attackers / unfixed flaw / using the flaw / verified patch.

3. Threat types. Malicious = deliberate (WannaCry, NHS 2017); accidental = unintended (GitLab deletion 2017); physical = physical damage (Kakao data-center fire 2022).

4. Risk matrix. Likelihood 1 unlikely, 2 possible, 3 likely; impact 1 minor, 2 serious, 3 severe. Score = L × I. **1–2 Low, 3–4 Medium, 6–9 High** (5 cannot occur). Write the working: "L 2 × I 3 = 6, High".

5. Patch vs restore. A verified patch closes that route of attack → it lowers **likelihood** (other weaknesses may remain). A tested restore means less is lost and service returns → it lowers **impact** (the event can still happen).

Week 3

1. Social engineering. Deception that influences a person's action by using the human factor. Invented story = **pretext**; **requested action** = what causes harm (password, code, payment, app). Levers: authority, fear, urgency, familiarity, reward, curiosity (plus secrecy).

2. Labels. Phishing = deceptive contact (broad); spear phishing = targeted; smishing = text; vishing = voice; impersonation = claimed identity. Each label describes a different feature, so one message can carry several.

3. Baiting, tailgating, deepfakes. Baiting = an attractive item invites a risky action (USB "exam answers"). Tailgating = following an authorized person into a restricted area. Deepfake = AI imitation of a face or voice.

A familiar face or voice is **recognition, not authorization**, so check before a sensitive action (Hong Kong case, about HK$200 million).

4. Warning signs. Unexpected contact + pressure + sensitive action (U + P + S): requests for passwords, codes, money or remote access. Read the full hostname **from the right**: `campus.example.verify-now.test` belongs to `verify-now.test`.

5. Weak evidence. Names, logos, fluent writing and layouts can be copied; HTTPS only protects the connection, also to a deceptive site. Stronger: an expected task and a contact route you already trust.

6. Pause, verify, report. Pause the action; verify through an independent route you obtained separately (open the known portal, call a known number); report through the official channel. Shared credentials or approved a login → reset access and end sessions through a trusted route, contact IT. Installed an app / remote access → stop using the device for sensitive tasks, get help from another device. Sent money → 112 and the bank immediately for payment suspension. Suspicious SMS/app → 118 KISA.

Week 4

1. Three checks. Identification = account claim; authentication = proof for that account; authorization = permission for the action. Account record = role, status, scope; session = recognizes later requests; permission check = decides access to each resource.

2. Guessing vs stuffing; online vs offline. Guessing tries likely passwords; stuffing reuses pairs leaked from another site. Online guesses go to the login service, so **attempt limits** and monitoring help; offline guesses test a **copied hash** on the attacker's device, so limits do not help (salt + Argon2id + long passwords do).

3. Long, unique passwords. Length resists guessing (NIST: 15+ characters password-only, 8 within MFA); uniqueness stops one leak from spreading; patterns like `Campus2026!` are predictable. A password manager generates and stores a different random password for every login.

4. MFA factors. Know (password, PIN), have (phone, authenticator app, security key), are (fingerprint, face). Valid: password + app code, key + PIN, password + fingerprint. Password + security question = know + know, so not MFA.

5. MFA completion. A verification screen alone does not enforce the rule (PortSwigger "2FA simple bypass"): every protected page must refuse access until MFA is complete. An unexpected approval prompt → **deny it** and investigate through the official service (Uber MFA fatigue).

6. Roles, scope, least privilege. Roles grant actions; scope limits resources; least privilege = only the access the assignment needs; join / change / leave updates access. Horizontal = another user's resource at the same level (Mina reads Joon's grade); vertical = a more privileged action (a student edits grades). In a log, find the "Allow" that the role table forbids.

Week 5

1. Malware types. Virus = runs when an infected file is executed and copies into other content; worm = spreads itself across networks to unpatched systems; Trojan = disguised as something useful; ransomware = encrypts or blocks, demands payment; spyware = collects information (keylogger); bot = remote operator uses the device.

2. Symptoms. A slow device may have an ordinary fault; evidence = processes, network connections, recent changes, scan results. Malware can hide with no warning window, and one attack can combine types (fake update = Trojan + spyware + ransomware).

3. Infection paths. Attachments and links (even from known contacts), fake updates / untrusted downloads, unpatched services (worms), USB devices, compromised suppliers (supply chain), plus excess privilege and weak configuration.

4. Controls. Updates (including firmware), secure configuration (disable unneeded services, restrict installs, encrypt), least privilege (standard accounts), endpoint protection with alerts investigated. Antivirus alone is insufficient because no tool detects everything.

5. Backups and recovery. Backups must be protected, separated (a connected backup can be encrypted too) and tested. Recovery must fix the original weakness and return to a trusted state: clean system → weakness fixed → credentials safe → data restored → monitored.

6. Suspected infection. Stop sensitive work, avoid unnecessary changes, report quickly and follow support guidance: experimenting can cause more harm and destroy evidence, and staff decide how to disconnect critical systems.

Week 6

1. LAN, WAN, Internet. LAN = limited local area (a lab); WAN = links networks over long distances (two campuses); Internet = many networks worldwide. Local printing still works when the Internet fails because the path stays local.

2. Tracing a request. Client starts the request → access point (wireless join) → switch (frames inside the LAN, MAC addresses) → router/firewall (IP packets between networks; the **default gateway** is the next router) → Internet routers → server provides the service.

3. Addresses and names. IP address identifies an interface (not a person); port identifies the service (443 HTTPS, 22 SSH); protocol = the rules; DNS = name → address; NAT lets many **private** addresses (192.168.x.x) share one **public** address.

4. URL and protocols. `https` = scheme, `lms.example.com` = domain, `/course/6` = path (default port 443). IP delivers packets between networks; TCP gives reliable, ordered delivery; HTTP defines requests and responses; TLS encrypts and checks certificates (HTTPS = HTTP + TLS).

5. HTTPS limits. It protects content in transit between TLS endpoints. Phishing sites can also get certificates; it does not protect data on an infected endpoint; IP addresses and timing may stay visible.

6. Named risks. Evil twin = fake access point (access); DNS spoofing = false DNS answers (DNS, but TLS still needs a valid certificate); on-path attacker = intercepts traffic in transit; exposed service = reachable in more ways than needed (boundary/server).

7. Controls and certificate warnings. Verified Wi-Fi (access), firewall rules (boundary), segmentation (guest ≠ staff), valid HTTPS (data in transit), server permissions (authentication + authorization). At a certificate warning: stop, do not enter credentials, and consider whether the cause is the device, the network or the website.